Guião Avançado: Integração Corporativa

Ecossistema Híbrido: Windows Server (AD DS) e Linux (Kerberos/Winbind/PAM)

1. O Desafio de Engenharia

Em ambientes corporativos de larga escala, a gestão descentralizada de identidades (criar utilizadores servidor a servidor) é insustentável e insegura. O standard da indústria resolve isto usando um **Serviço de Diretório Central** — tipicamente o Microsoft Active Directory (AD DS). O nosso desafio de engenharia é fazer com que um servidor Linux, que nativamente não compreende a arquitetura Microsoft, confie e delegue a sua segurança a este servidor central.

Neste laboratório, contamos com quatro Máquinas Virtuais no Proxmox, divididas em dois blocos funcionais:

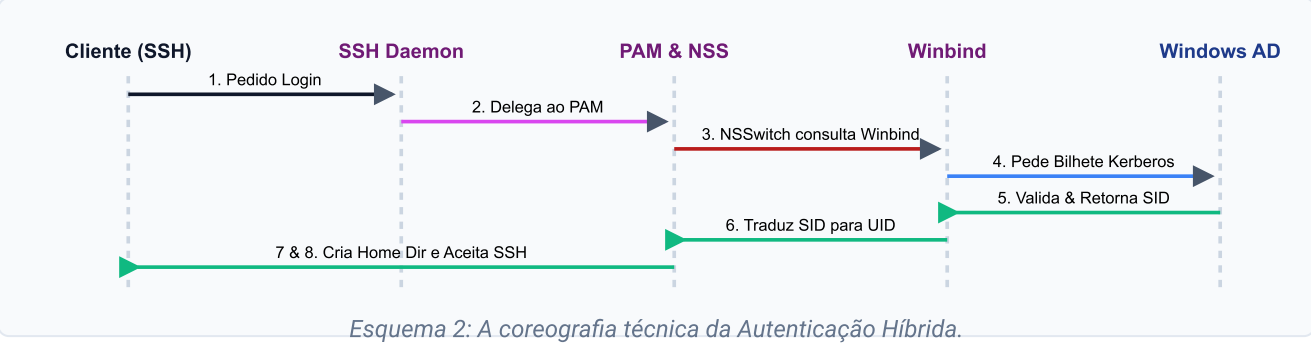


Esquema 1: Topologia física das Máquinas Virtuais no Proxmox.

A Missão: O departamento de TI cria a conta do utilizador "orlando.admin" exclusivamente no Windows Server. Quando o Orlando usa a sua máquina Cliente (Windows ou Ubuntu) para tentar aceder via SSH ao Ubuntu Server, o Linux deve consultar o Windows Server, verificar as credenciais e conceder acesso sem nunca ter armazenado localmente a senha do Orlando.

2. Anatomia do Fluxo de Autenticação Cruzada

A magia acontece através de uma complexa cadeia de delegação de responsabilidades. Para configurar o sistema corretamente, é vital entender a jornada completa do pedido de login:



Esquema 2: A coreografia técnica da Autenticação Híbrida.

O Detalhe dos 8 Passos:

1. **O Cliente** inicia uma ligação SSH para o IP do Linux com o utilizador `orlando.admin`.
2. O serviço **SSH Daemon (sshd)** não avalia a password. Passa o desafio diretamente para o **PAM** do Linux.
3. O **PAM** nota que `orlando.admin` não existe no ficheiro local `/etc/passwd`. Graças ao ficheiro **NSSwitch**, ele sabe que deve procurar na rede.
4. O módulo do PAM direciona o pedido para o **Winbind** (o serviço diplomata do Samba). O Winbind traduz o pedido para linguagem Microsoft (protocolos Kerberos e RPC).
5. O **Windows Server (AD DS)** analisa o "Ticket" Kerberos, valida a palavra-passe contra a sua base de dados central, e responde com o Security Identifier (SID) da conta.
6. O **Winbind** recebe o SID (que é um código gigantesco da Microsoft) e traduz-lo para um número simples (UID) que o Linux entende (ex: 10005).
7. O **PAM** recebe a confirmação. Aciona o módulo `pam_mkhomedir.so` para criar a pasta pessoal do utilizador dinamicamente no disco do Linux.
8. O **SSH** abre a porta de entrada. O utilizador ganha a sua shell.

3. Fundações Críticas: DNS e NTP

Antes de alterar qualquer ficheiro de autenticação, a máquina Linux necessita de resolver dois problemas arquiteturais para falar com o Windows: descobrir onde ele está (DNS) e garantir que o relógio não difere (NTP).

> 🚨 **A Criptografia Kerberos e o Tempo:** O protocolo Kerberos usado pela Microsoft previne ataques de repetição ("Replay Attacks") colocando um carimbo de tempo rigoroso nos bilhetes. Se o relógio do Ubuntu diferir mais de **5 minutos** do relógio do Windows Server, a autenticação será rejeitada com erro silencioso, independentemente de a senha estar correta.

Configuração de Rede (Netplan)

O Ubuntu Server deve usar **exclusivamente** o IP do Windows Server como o seu servidor de DNS primário. Só assim ele consegue resolver os registos de serviço especiais (SRV) que o Active Directory cria para se anunciar na rede.

1. Edite o ficheiro do Netplan: `sudo nano /etc/netplan/00-installer-config.yaml`
2. Configure as diretivas de `nameservers` e `search` para apontarem para o domínio (vamos assumir que o Domínio Windows se chama `lab.local` e o IP é `192.168.1.100`):

```
      network: version: 2 ethernets: ens18: dhcp4: false addresses: [192.168.1.50/24]
nameservers: addresses: [192.168.1.100] # O IP do Active Directory search: [lab.local]
# O nome do Domínio
```

Aplique com `sudo netplan apply` e garanta que o comando `ping lab.local` resolve corretamente o IP do servidor Windows.

Configuração de Tempo (Chrony/NTP)

Assegurem que o serviço de relógio (chrony ou systemd-timesyncd) está sincronizado com um servidor de tempo global, ou preferencialmente, apontado ao próprio Windows Server para garantir paridade exata de milissegundos.

4. O Motor de Busca: Kerberos e NSSwitch

Agora entramos na configuração a baixo nível. Em vez de ferramentas automáticas, vamos ditar ao Linux exatamente que reino criptográfico usar e onde procurar utilizadores.

Configurar o Reino Kerberos (`krb5.conf`)

O Kerberos usa o conceito de REALM (escrito sempre em maiúsculas). Temos de informar o serviço local sobre qual é o REALM da nossa rede.

1. Abra o ficheiro: `sudo nano /etc/krb5.conf`
2. Procure a secção `[libdefaults]` e force a variável `default_realm`:

```
[libdefaults] default_realm = LAB.LOCAL dns_lookup_realm = false dns_lookup_kdc = true
```

(A diretiva `dns_lookup_kdc = true` permite ao Linux usar o DNS que configurámos no passo anterior para descobrir sozinho onde está o servidor de chaves Kerberos, poupando a necessidade de escrevermos IPs aqui).

Configurar o Comutador de Nomes (`nsswitch.conf`)

O ficheiro Name Service Switch (NSS) dita a ordem pela qual o sistema operativo procura identidades. Por defeito, ele apenas procura nos ficheiros locais (`files`). Temos de o instruir a consultar o `winbind` caso não encontre localmente.

1. Abra o ficheiro: `sudo nano /etc/nsswitch.conf`
2. Modifique as linhas `passwd` e `group` para adicionarem o winbind ao fim da cadeia de procura:

```
# /etc/nsswitch.conf passwd: files systemd winbind group: files systemd winbind shadow: files systemd gshadow: files systemd
```

5. O Diplomata: Samba e Winbind

O Samba é a suite de software responsável por emular os protocolos da Microsoft. Vamos editar a sua configuração mestre para definir como é que os identificadores são traduzidos (ID Mapping).

1. Edite o ficheiro central do Samba: `sudo nano /etc/samba/smb.conf`
2. Na secção `[global]`, apague o que lá está e insira esta arquitetura exata de mapeamento:

```
[global] workgroup = LAB realm = LAB.LOCAL security = ads # Configurações do Winbind (O Tradutor) winbind use default domain = yes winbind enum users = yes winbind enum groups = yes # O processo de Mapeamento (ID Map) idmap config * : backend = tdb idmap config * : range = 3000-7999 idmap config LAB : backend = rid idmap config LAB : range = 10000-999999 template shell = /bin/bash
```

(O backend `rid` garante que o número gerado no Linux para um dado utilizador será sempre matematicamente consistente e baseado no seu SID original do Windows).

Casamento com o Domínio e Prova de Vida

Com os ficheiros preparados, execute a junção oficial comunicando com o Windows Server:

```
sudo net ads join -U Administrador sudo systemctl restart winbind smbd nmbd
```

Para testar cientificamente se o NSSwitch e o Winbind estão a funcionar, não faça SSH ainda. Peça ao Linux para listar contas:

```
getent passwd
```

Se, no final da listagem do terminal, aparecer o seu `orlando.admin` seguido do número UID (ex: 10005), a comunicação em rede foi um absoluto sucesso.

6. O Segurança: PAM (Pluggable Authentication Modules)

O último passo é afinar o guarda da porta para garantir que ele compreende o que fazer com estes utilizadores em trânsito.

1. **Garantir a criação de Diretórios Pessoais:** O Windows Server não diz ao Linux onde gravar ficheiros. O PAM tem de tratar disso antes de libertar o terminal.

   ```
   sudo nano /etc/pam.d/common-session
   ```

   Adicione na última linha do ficheiro:

   ```
   session required pam_mkhomedir.so skel=/etc/skel/ umask=0022
   ```

2. **Ativar o Módulo Winbind no PAM:** O Ubuntu faz a gestão dos ficheiros `common-auth` e `common-account` de forma exímia através de um utilitário de interface.

   ```
   sudo pam-auth-update
   ```

   Assegure-se de que a caixa *Winbind NT/Active Directory authentication* tem um asterisco [*] marcado. Prima Enter.

Neste ponto, o projeto está terminado. Realize o teste com `ssh orlando.admin@ip_do_linux`. O acesso será concedido contra a Active Directory.

7. Fontes e Bibliografia Oficial (Research & Standards)

A arquitetura e configuração técnica aplicadas neste laboratório resultam da consolidação das seguintes documentações oficiais (RFCs, manuais de software e guias da indústria):

- **Samba / Winbind Official Technical Specs:**
  "Samba idmap_rid Backend Documentation". The Samba Team. Consultado para otimização da diretiva `backend = rid` na tradução algorítmica de SIDs do Windows para UIDs no `/etc/samba/smb.conf`.
- **Kerberos Network Authentication Service (V5):**
  RFC 4120 (IETF). Consultado para enquadramento das restrições de desvio de relógio temporal (Time Skew Requirements - secção 3.2.3), fundamentando a necessidade crítica do NTP.
- **Linux-PAM (Pluggable Authentication Modules):**
  "pam_mkhomedir - create users home directory". Linux-PAM System Administrators' Manual. Usado para integração de sessão no `/etc/pam.d/common-session`.
- **Name Service Switch (NSS):**
  "The GNU C Library - Name Service Switch". GNU.org. Documentação estrutural para alteração do mapeamento de pesquisa em `/etc/nsswitch.conf`.
- **Integração Canonical / Ubuntu Server:**
  "Ubuntu Server Guide: Active Directory Integration". Canonical Ltd. Referência sobre a utilização utilitário `pam-auth-update` para injeção e sobreposição segura de regras Winbind e PAM.
- **Microsoft Active Directory Domain Services:**
  "AD DS Architecture and Windows Server Authentication". Microsoft Learn. Consultado para o mapeamento da topologia central (Controlador de Domínio) e validação de tokens RPC/Kerberos em redes híbridas.
- **Configuração de Rede Neutra (Netplan):**
  "Netplan Reference: Network Configuration". Netplan.io. Base técnica para a definição de servidores de DNS primários (`nameservers`) essenciais para a resolução do Active Directory em ambientes Linux.
- **Defesa e Bloqueio Brute-Force (pam_faillock):**
  "Security Hardening: Locking User Accounts After Failed Login Attempts". RHEL Documentation / man pam_faillock. Base teórica e técnica para a implementação do módulo de defesa contra ataques de força bruta no SSH abordado na fase defensiva do projeto.
- **Algoritmo MFA / Autenticador (TOTP):**
  RFC 6238 (IETF) - "TOTP: Time-Based One-Time Password Algorithm". Especificação oficial que suporta o módulo `libpam-google-authenticator`, comprovando o funcionamento offline da solução de autenticação de dois fatores.